

Myanmar Banking Sector Cyber Resilience Blueprint

A preventive framework to protect Myanmar’s banks against ransomware and data extortion — designed for a **Central Bank of Myanmar**–led sector rollout, built on the Fortinet Security Fabric.

Catalyst:

AYA Bank ransomware incident

Prepared by

Fortinet · Myanmar

June 2026

THREAT SNAPSHOT	
Target	AYA Bank (Myanmar)
Threat actor	LAPSUS\$ group
Claimed exfiltration	~120 GB · full platform + PII
Data at risk	Card, BNPL, customer payments
Extortion model	Single-buyer sale / ransom
Surfaced	23 Jun 2026 · leak site

01 WHY THIS MATTERS TO THE WHOLE SECTOR

One bank was named. Every bank is exposed.

LAPSUS\$ has publicly claimed a full platform compromise of AYA Bank, including personally identifiable information and payment card data, with a threatened sale to a single buyer. The same intrusion pattern — identity-led, low-cost, repeatable — works against any institution that has not closed the same gaps. For the Central Bank of Myanmar, the exposure is **systemic**: a

confidence shock to one bank can ripple across the payment system and public trust in digital banking.

~120 GB

Claimed full data dump, including PII & card files

100%

“Main platform” claimed compromised — not a single system

1 buyer

Double extortion: pay, or customer data is sold

\$0 0-day

Pattern relies on stolen identity, not exotic exploits

02 ANATOMY OF THE ATTACK

An identity-first kill chain — and where it breaks

LAPSUS\$ is not known for zero-day wizardry. Their playbook is human and identity-centric: buy or phish credentials, defeat weak MFA, log in as a trusted user, move laterally, and exfiltrate for extortion. Each stage maps to a known MITRE ATT&CK technique — and each has a corresponding Fortinet control that stops it.

STAGE 1 Access brokering Buy stolen credentials & infostealer logs from darkweb brokers. T1078 · T1589 ✓ FortiRecon darkweb watch	STAGE 2 Social engineering Vishing & helpdesk pretexting; MFA fatigue prompt bombing. T1566 · T1621 ✓ FortiMail + FortiPhish	STAGE 3 Valid account login Authenticate as a real user; bypass SMS / push MFA. T1078 ✓ FortiAuthenticator FIDO2	STAGE 4 Lateral movement Escalate privilege; reach core platform from one foothold. T1021 · T1068 ✓ FortiGate + FortiPAM	STAGE 5 Exfiltration Stage and pull ~120 GB of PII & card data out of the bank. T1567 · T1041 ✓ FortiDLP + FortiEDR	STAGE 6 Extortion Leak site listing & countdown; pay or sell pressure. T1657 ✓ FortiRecon + SOC IR
--	---	---	---	--	---

⚠ Two lessons for the sector: defend identity first (the attack begins and pivots on stolen logins), and segment aggressively — segmentation is the difference between “one compromised laptop” and “the entire core banking platform.”

Six control domains, one integrated Security Fabric

A bank does not need fifteen disconnected tools; it needs six control outcomes that work together. The Fortinet Security Fabric delivers all six on one operating system and one console — closing the seams between products where attackers like LAPSUS\$ operate.

D1



Identity & access hardening

Kills the attack at its root. **Phishing-resistant MFA (FIDO2), number matching, and privileged access control** defeat MFA fatigue, stolen credentials and help desk pretexting.

FORTINET

FortiAuthenticator

FortiToken

FortiPAM

FortiNAC

SWIFT 4.1/4.2/5.1

PCI 7&8

ISO A.5.15/A.8.5

NIST PR.AA

D2



Email & human layer defense

Closes the most common front door. **Anti-phishing, anti-BEC, attachment detonation** and continuous staff simulation reduce the click that starts the breach.

FORTINET

FortiMail

FortiSandbox

FortiPhish

FortiRecon

SWIFT 7.2

PCI 5&12.6

ISO A.6.3/A.8.7

NIST PR.AT

D3



Endpoint & ransomware kill

Stops execution and encryption.

Behavior-based EDR halts ransomware in real time and rolls back changes, even for never-seen variants.

FORTINET

Forti**EDR**

Forti**Client**

Forti**XDR**

Forti**Sandbox**

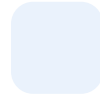
SWIFT 6.1/6.2

PCI 5&11

ISO A.8.7

NIST PR.PS/DE.CM

D4



Segmentation & zero trust access

Contains the blast radius. **Internal segmentation firewalling and ZTNA** stop lateral movement — turning a single foothold into a dead end, not a full platform dump.

FORTINET

Forti**Gate**

Forti**SASE**

Forti**NAC**

Forti**Manager**

SWIFT 1.1/2.1

PCI 1&4

ISO A.8.20/A.8.22

NIST PR.IR

D5



Detection, SOC visibility & response

Cuts dwell time. **SIEM/SOAR analytics, deception and dark web monitoring** surface the intrusion — and the leak listing — early enough to act.

FORTINET

Forti**SIEM**

Forti**SOAR**

Forti**Analyzer**

Forti**Deceptor**

Forti**NDR**

SWIFT 6.4/6.5/7.1

PCI 10&11.5

ISO A.8.15/5.24

NIST DE&RS

D6



Data protection, backup & recovery

Defeats double extortion. **Data loss prevention plus assured, immutable recovery** means stolen data is unreadable and operations restore without paying.

FORTINET

Forti**DLP**

Forti**Gate DLP**

Forti**CNAPP**

Forti**Guard**

SWIFT 2.5A

PCI 3&4

ISO A.8.12/A.8.13

NIST PR.DS/RC

HYBRID BY DESIGN

Covers the whole estate — on-premise and AWS cloud

Banking workloads — including card and payment platforms — increasingly run in public cloud. Under the AWS Shared Responsibility Model, AWS secures the cloud; the bank stays responsible for everything *in* it — and most exposures come from that side: misconfigured data stores, over-permissioned identities, unprotected workloads. Fortinet secures the bank's half consistently, on-premise and in AWS, applying the same six control domains.

AWS secures — security of the cloud

Physical data centers, hardware, the global network and managed service infrastructure.

Fortinet secures the bank's side — security in the cloud

Cloud posture & configuration, identities, segmentation, workloads, apps/APIs and data — the same controls, applied inside AWS.

FortiGate CNF

FortiCNAPP

FortiWeb Cloud

FortiGate VM

FortiClient

Why it matters here: FortiCNAPP continuously finds the cloud misconfigurations and exposed data stores that lead to card data leaks — closing the cloud-side gap as firmly as the on-premise one.

➤ [Case: WeLab virtual bank on AWS](#)

Underpinned by FortiGuard Labs & FortiAI. Every domain draws on the same real-time global threat intelligence and AI-assisted detection, so a signal seen anywhere in the Fabric protects every bank in the program — the foundation for sector-wide threat sharing under the Central Bank of Myanmar.

04 THE PREVENTIVE BLUEPRINT, IN PHASES

A firm, staged guideline — not a wish list

All seven control domains — the six core layers plus cloud — sequenced into three enforceable phases. Phase 1 is the minimum baseline every licensed

institution must meet; Phases 2–3 deepen resilience and scale with each bank's tier — clear, measurable and supervisable.

PRINCIPLE 01

Identity first

Every login phishing-resistant; every privilege controlled. The attack starts here — so does the defense.

PRINCIPLE 02

Segment always

No flat networks. Contain by default, so one foothold never becomes the whole platform.

PRINCIPLE 03

Assume breach

Detect fast, respond automatically, recover without paying. Resilience is the goal — not perfection.

Control domain	PHASE 1 · 0–90 DAYS Contain the identity gap	PHASE 2 · 3–9 MONTHS Limit the blast radius	PHASE 3 · 9–18 MONTHS Sector-grade resilience
D1 · Identity & access FortiAuthenticator, FortiPAM	Phishing-resistant MFA (FIDO2) for all staff & admins; privileged access vaulting on core banking.	Single sign-on + conditional access across all apps; eliminate standing privilege.	Continuous identity risk scoring; a sector-wide MFA standard under CBM.
D2 · Email & human FortiMail, FortiPhish	Secure email gateway + anti-BEC on every mailbox; block macro-borne malware.	Quarterly phishing simulation with reporting & targeted coaching.	Awareness KPIs in supervision; brand impersonation takedown via FortiRecon.
D3 · Endpoint FortiEDR, FortiClient	Behavioral EDR on 100% of endpoints & servers; default deny ransomware behavior.	Automated containment + sandbox detonation of unknown files.	Managed threat hunting / XDR; routine rollback & restore drills.
D4 · Segmentation FortiGate, FortiSASE	Isolate core banking & admin zones; kill flat east-west paths.	ZTNA replaces flat VPN; micro-segmentation around crown jewels.	Deny-by-default east-west; continuous policy assurance.
D5 · Detection & SOC FortiSIEM, FortiAnalyzer	Centralize logs; baseline high-fidelity alerting.	SIEM correlation + tested IR playbooks + incident reporting to CBM.	24x7 SOC, deception & sector threat sharing (FinCERT).
D6 · Data & recovery FortiDLP, FortiGuard	DLP on card/PII egress; immutable, offline-capable backups.	Encryption at rest & in transit; regularly tested restores.	Assured RTO/RPO; periodic red team & recovery exercises.

Control domain	PHASE 1 · 0–90 DAYS Contain the identity gap	PHASE 2 · 3–9 MONTHS Limit the blast radius	PHASE 3 · 9–18 MONTHS Sector-grade resilience
D7 · Cloud & hybrid (AWS) FortiCNAPP, FortiGate CNF	Inventory AWS accounts & workloads; turn on CSPM (FortiCNAPP) to find misconfigurations; lock down public data stores & identities.	Cloud-native firewalling (FortiGate CNF) + WAF for public apps/APIs; least-privilege cloud IAM (CIEM).	Code-to-cloud workload protection + automated compliance; one unified on-prem & AWS policy and SOC view.



Firm baseline: Phase 1 is non-negotiable for every licensed bank and MFI — achievable within one quarter. Attestation aligns to the annual SWIFT CSP cycle and CBM supervisory review, giving the regulator a clear, auditable line of sight.

05 PROVEN IN THE FIELD

Not theory — Fortinet stops ransomware in production

Published customer stories and independent testing show the same controls in this blueprint defeating real ransomware across financial services and critical infrastructure. A selection of verifiable references:

FINANCIAL SERVICES · MULTINATIONAL BANK

Hardened against rising ransomware with AI/ML-powered FortiGate IPS

Facing the exit of its incumbent IPS vendor, the bank ran a competitive selection and standardized on FortiGate NGFW with consolidated IPS — topped malware and threat prevention coverage against its own threat samples, with no performance penalty.

FortiGate IPS

Security Fabric

➤ Fortinet customer story

CRITICAL INFRASTRUCTURE SERVICES

Ransomware detected, contained & remediated with FortiEDR

Using FortiEDR forensics as a “black box,” the response team replayed the full attack — from a macro-enabled spreadsheet through C2, lateral movement and encryption — blocked attacker traffic, cleaned every host, then retained FortiGuard for ongoing managed protection.

FortiEDR

FortiGuard IR

➤ Fortinet case study (PDF)

INDEPENDENT VALIDATION · MITRE

FortiEDR blocked 100% of attacks in MITRE Engenuity ATT&CK — two years running

In MITRE’s independent evaluation (Turla threat actor), FortiEDR recorded 100% prevention, 98% visibility and a 95% analytical detection rate — well above the ~73% vendor average — validating the endpoint layer of this blueprint.

FortiEDR

3rd party tested

➤ MITRE Engenuity results

78%
felt prepared

➔

~50%
still breached

Preparation is not protection. Fortinet’s 2023 global survey found most organizations felt ready for ransomware — yet around half were still hit. Integrated, enforced controls are what close the gap. Source · Fortinet

One Fabric beats a drawer full of disconnected tools

Ransomware exploits the *seams* between products — the gaps where a firewall, an EDR and an identity tool from three different vendors don't talk to each other. Fortinet removes the seams: one operating system, one console, automated cross-control response. Here is how that compares.

100%

attacks blocked by FortiEDR in MITRE ATT&CK Eval — two years running

5

2024 Gartner® Magic Quadrants — only vendor recognized across all five

1 OS

FortiOS unifies the entire Fabric on one console & policy

#1

highest in Ability to Execute, Gartner® SD-WAN MQ, four years running

	Fortinet Security Fabric Integrated platform	Isolated point products Best of breed, multi-vendor	Other single-vendor stack Partially integrated
Capability against ransomware			
Native integration & auto-correlation	Built-in All controls share FortiOS and correlate automatically.	Gap API glue & SIEM stitching; brittle and slow.	Partial Acquired modules, uneven integration.
Cross-control automated response (seconds)	Yes NGFW, EDR & identity act as one to contain instantly.	Manual Each tool acts alone; humans must correlate.	Partial Some playbooks, rarely end-to-end.
Stop lateral movement (internal segmentation)	Native FortiGate ISFW + ZTNA built in.	Partial Possible, separately bought & managed.	Partial Depends on add-on modules.
Shared real-time threat intelligence	Fabric-wide FortiGuard pushes to every element at once.	Siloed Separate feeds per vendor.	Partial Single feed, narrower sensor base.
Single console & unified policy	One pane FortiManager + FortiAnalyzer across all.	Many UIs Swivel-chair operations across consoles.	Partial Consolidating, still multiple panes.
Endpoint ransomware rollback	Yes FortiEDR auto-remediates & restores files.	Vendor-dependent Only if the EDR product supports it.	Varies Depends on the bundled module.

	Fortinet Security Fabric Integrated platform	Isolated point products Best of breed, multi-vendor	Other single-vendor stack Partially integrated
Capability against ransomware			
Independent 100% MITRE prevention	 Proven FortiEDR, two years running.	 Varies Results differ widely by vendor.	 Mixed Mixed evaluation outcomes.
TCO & operability for lean teams	 Lowest Consolidation cuts cost & staffing load.	 Highest Greatest integration & headcount cost.	 Premium Better than multi-vendor, priced high.
Hybrid & public cloud (AWS) protection	 One Fabric Same policy spans data center & AWS; FortiGate CNF + FortiCNAPP native.	 Split Separate cloud tools & console from on-prem.	 Partial Cloud add-ons, uneven parity with on-prem.
Built for sector-wide rollout (DfSIB → MFI)	 Designed for it One platform scales every tier; local channel ready.	 Hard Difficult to standardize across many banks.	 Costlier Possible, but more expensive to scale.

Comparison reflects architectural model and is intended for sector planning; specific capabilities vary by product configuration and licensing. Validation points: MITRE Engenuity ATT&CK® Evaluation and 2024 Gartner® Magic Quadrant™ reports (SD-WAN; Enterprise Wired & Wireless LAN; plus Network Firewalls, SSE and Single-Vendor SASE). Gartner does not endorse any vendor and Magic Quadrant placements differ by category.

07 COMPLIANCE & STANDARDS CROSSWALK

Mapped to the frameworks Myanmar’s banks already answer to

The blueprint is not a new standard to learn — it is a way to satisfy existing ones. Each control domain maps to Central Bank of Myanmar supervisory expectations and to the four international frameworks that licensed banks

(especially those on SWIFT and handling card data) are measured against. This makes regulatory rollout defensible and audit-ready.

Control domain	CBM supervisory expectation	SWIFT CSP CSCF v2025	PCI DSS v4.0	ISO/IEC 27001:2022	NIST CSF 2.0
D1 — Identity & access MFA, privileged access	Risk Management Guideline — access & operational risk; CII protection (draft Cybersecurity Law)	4.1, 4.2, 5.1, 5.2, 1.2	Req 7, Req 8 (8.4–8.5 MFA)	A.5.15, A. 5.17, A. 8.2, A.8.5	PR.AA
D2 — Email & human layer anti-phishing, awareness	Operational risk & staff awareness; AML/CFT vigilance	7.2 (training & awareness)	Req 5, Req 12.6	A.6.3, A. 8.7, A. 5.14	PR.AT, DE.CM
D3 — Endpoint & ransomware EDR, anti-malware	Technology/ operational risk controls; incident prevention	6.1, 6.2, 2.3	Req 5, Req 11	A.8.7, A. 8.16	PR.PS, DE.CM, RS.MI
D4 — Segmentation & ZTNA contain blast radius	Critical Information Infrastructure protection (draft Cybersecurity Law)	1.1, 1.4, 2.1, 5.4	Req 1, Req 4	A.8.20, A. 8.22, A. 8.23	PR.IR, PR.AA
D5 — Detection & response SOC, SIEM, IR	Incident reporting to CBM; national CERT coordination (draft law)	6.4, 6.5, 7.1, 7.3	Req 10, Req 11.5, 12.10	A.8.15, A. 8.16, A. 5.24–5.28	DE.*, RS.*
D6 — Data, backup & recovery DLP, immutable restore	Customer information confidentiality; protection of personal information (draft law)	2.5A, 3.1	Req 3, Req 4, Req 12.10.1	A.8.10– 8.13	PR.DS, RC.*
D7 — Cloud & hybrid (AWS) posture, workloads, data	Cloud / outsourcing & third-party risk; data confidentiality (draft Cybersecurity Law)	1.1, 2.1, 2.3	Req 2, 6, 11; App. A1 (cloud)	A.5.23, A. 8.20–8.23	GV.SC, ID.AM, PR.IR

CBM Central Bank of Myanmar SWIFT CSP Customer Security Programme · CSCF v2025 (25 mandatory controls)

PCI DSS v4.0 directly relevant to the leaked card data ISO 27001:2022 Annex A NIST CSF 2.0 functions

From one bank's breach to a sector's baseline

The Central Bank of Myanmar is uniquely placed to convert this incident into sector-wide resilience: issue a minimum controls baseline, supervise attestation, and stand up shared threat intelligence. A phased, tiered model keeps it achievable for banks of every size — from DfSIBs to microfinance institutions.



One Fabric, the full kill chain, built for lean teams

A sector program needs breadth, integration and operability — not fifteen vendors for ten banks. Fortinet delivers the entire blueprint on a single platform, which is exactly what makes it deployable across institutions of very different sizes.



Full kill chain coverage

Identity, email, endpoint, network, SOC and data — every stage of the LAPSUS\$ pattern has a Fortinet control. No seams for attackers to slip through.



One platform, one console

The Security Fabric runs on a common OS and management plane — lower complexity and TCO, vital for Tier 2/3 banks and MFIs with small security teams.



AI & global threat intel

FortiGuard Labs and FortiAI deliver real-time, shared intelligence — the technical basis for a CBM-coordinated sector threat-sharing model.



Standards aligned by design

Controls map cleanly to SWIFT CSP, PCI DSS, ISO 27001 and NIST CSF — easing attestation and CBM supervisory review for every member bank.

Delivery is local, not theoretical. Fortinet already protects financial institutions in Myanmar (including **KBZ Bank**) and is supported by established in-country distribution and channel partners such as **VSTECS** — so a Central Bank of Myanmar-led rollout can be resourced and sustained nationally, not just designed on paper.

PROPOSED NEXT STEPS

Turn one breach into the sector's turning point.

Fortinet proposes a short, structured engagement with the Central Bank of Myanmar and leading banks to move from this blueprint to a funded, supervised program.

01

02

03

04

Sector briefing

Executive walkthrough of the AYA pattern & the baseline with CBM and member banks.

Reference architecture

Joint workshop to set the minimum controls directive and tiered model.

Lighthouse pilot

90-day Phase 1 deployment at a Tier 1 bank as the proof point.

Sector rollout

Phased national program with attestation & a CBM maturity dashboard.

Fortify Your Cybersecurity.

Securing people, devices and data everywhere — for Myanmar's banking sector.

Fortinet · Myanmar

Banking Sector Cyber Resilience Blueprint

Prepared for the Central Bank of Myanmar & licensed banks

Version 1.0 · June 2026 · Confidential

Disclaimer. This document is prepared for sector resilience planning. References to the AYA Bank incident are based on open source threat intelligence and public threat actor claims circulating as of June 2026 and have not been independently confirmed by AYA Bank or the Central Bank of Myanmar. MITRE ATT&CK technique IDs are indicative of the observed intrusion pattern. Control framework mappings are advisory and should be validated against each institution's formal scope and the current published versions of each standard. Product names are trademarks of Fortinet, Inc.

Reference standards: SWIFT Customer Security Controls Framework v2025 · PCI DSS v4.0 · ISO/IEC 27001:2022 · NIST Cybersecurity Framework 2.0 · Central Bank of Myanmar Banking Regulation & Risk Management guidance and draft Cybersecurity Law.